



ALMA MATER STUDIORUM
UNIVERSITÀ DI BOLOGNA

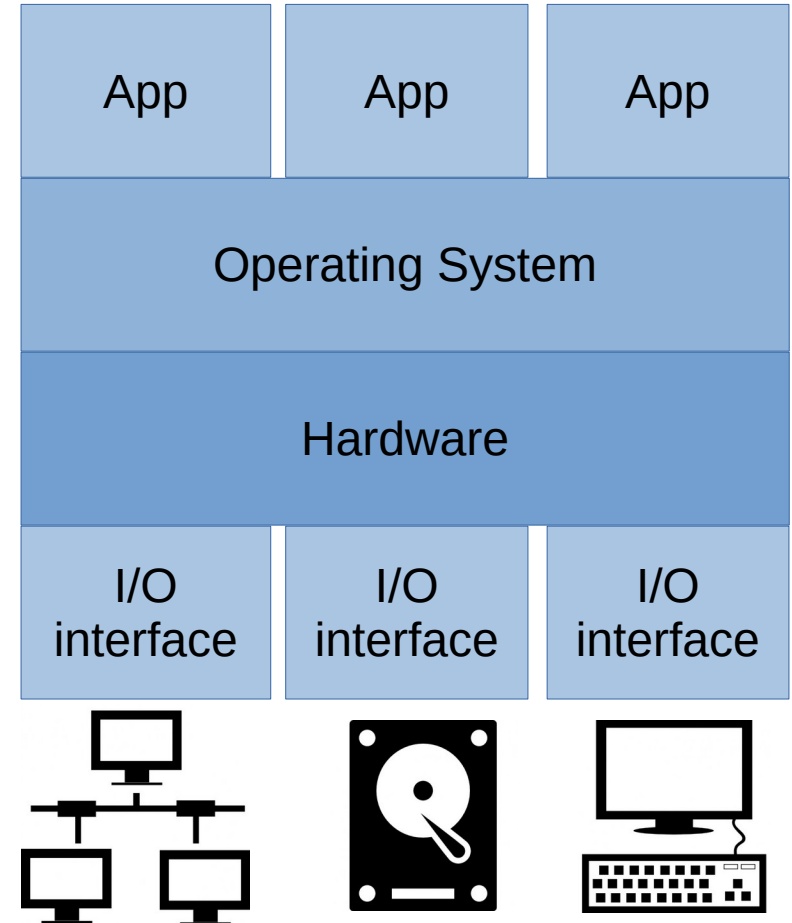
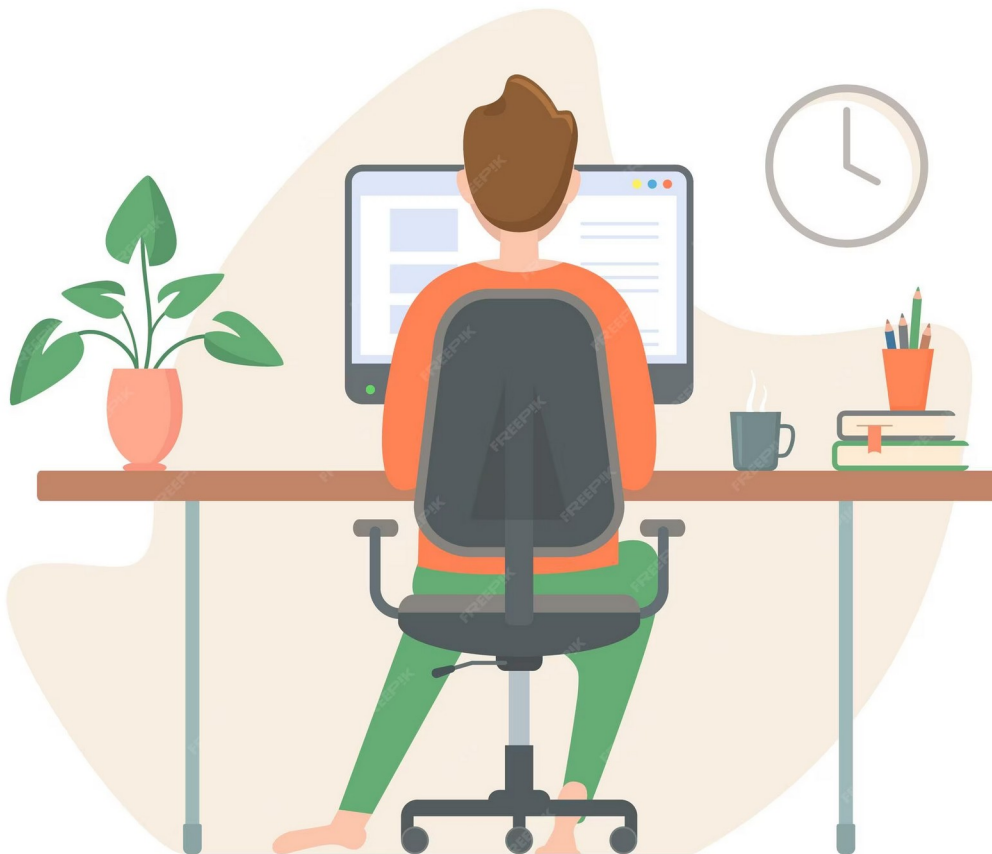
Laboratorio di Sicurezza Informatica

Offensive security I Reconnaissance & Assessment

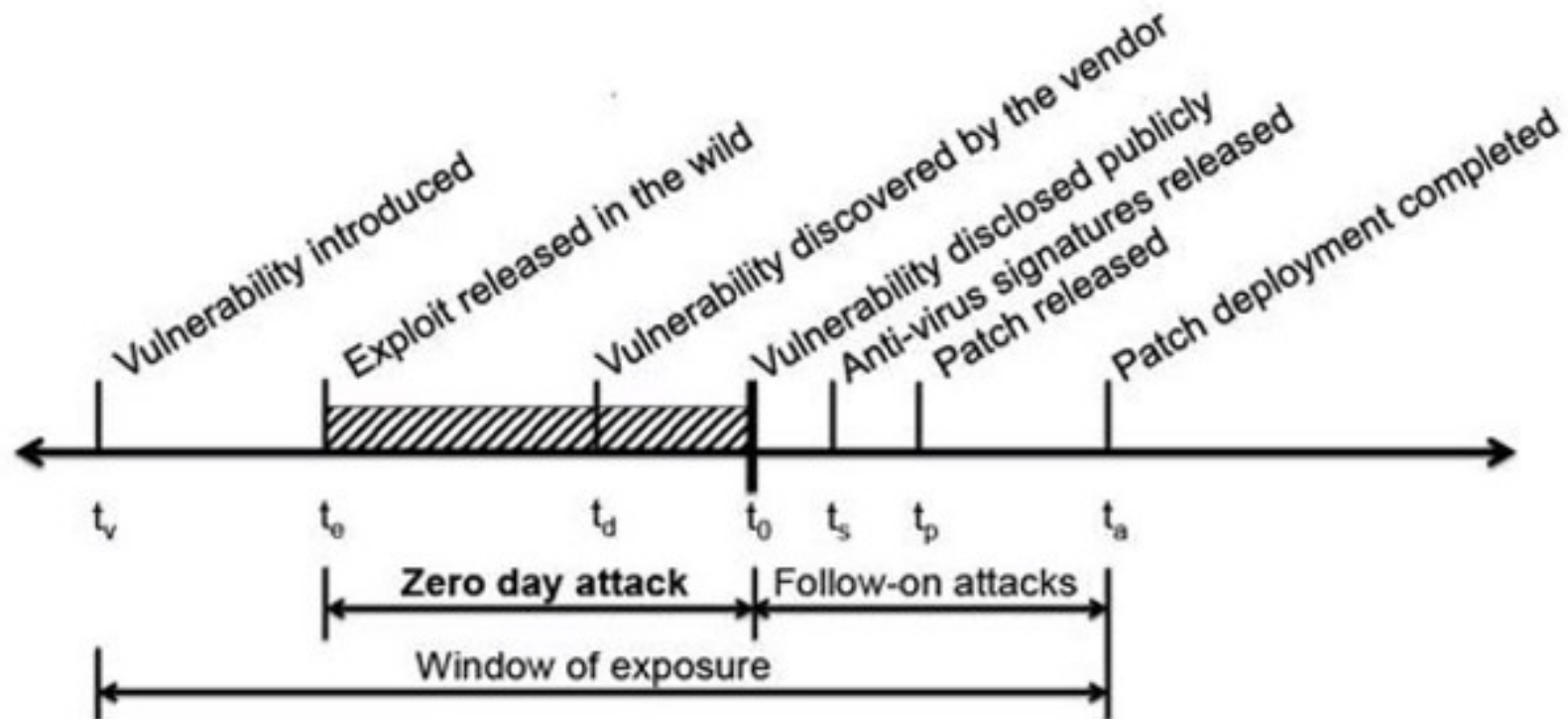
Marco Prandini

Dipartimento di Informatica – Scienza e Ingegneria

Dove si annidano le vulnerabilità?



Il ciclo di vita della vulnerabilità



Leyla Bilge, Tudor Dumitras, [Before We Knew It: An Empirical Study of Zero-Day Attacks In The Real World](#), ACM CCS 2012.

Modi e tempi

- **Vulnerabilità zero-day**: una vulnerabilità sconosciuta a coloro che dovrebbero essere interessati a mitigarla
- **Finestra di opportunità**: tempo trascorso da quando il primo exploit del software diventa attivo al momento in cui il fornitore interessato rilascia una patch e viene applicata
- **Attacco zero-day**: un attacco che si verifica durante la finestra di opportunità
 - Nel 2005 la durata media di una finestra era di 54 giorni, nel 2014 è cresciuta a quasi 12 mesi
- **Gli attacchi si intensificano dopo la finestra, perché tutti vengono a conoscenza della vulnerabilità**
 - tipicamente scansioni massicce iniziano dopo 15 minuti dalla pubblicazione della CVE

Pubblicare le vulnerabilità

- La comunità pubblica le vulnerabilità scoperte, secondo un principio di *responsible disclosure*
 - Common Vulnerabilities and Exposures <http://cve.mitre.org/>
 - National Vulnerability Database <http://nvd.nist.gov/>
 - Open Sourced Vulnerability Database <http://osvdb.org/>
 - SecurityFocus <http://www.securityfocus.com/vulnerabilities>
 - US-CERT <http://www.kb.cert.org/vuls/>
- Ci sono iniziative per cercarle attivamente
 - Google project zero
 - Programmi di *bug bounty* che le pagano profumatamente (es. Zerodium)
- Esistono database di exploit pronti per sfruttarle
 - <https://www.cvedetails.com/>
 - <https://www.exploit-db.com/>
 - <https://packetstormsecurity.com/>

I tempi di reazione di “uno bravo”

■ Vulnerabilità grave in Firefox

- Lettore PDF integrato, scritto in JavaScript
- Gli si manda un JavaScript mascherato da PDF, lo esegue!

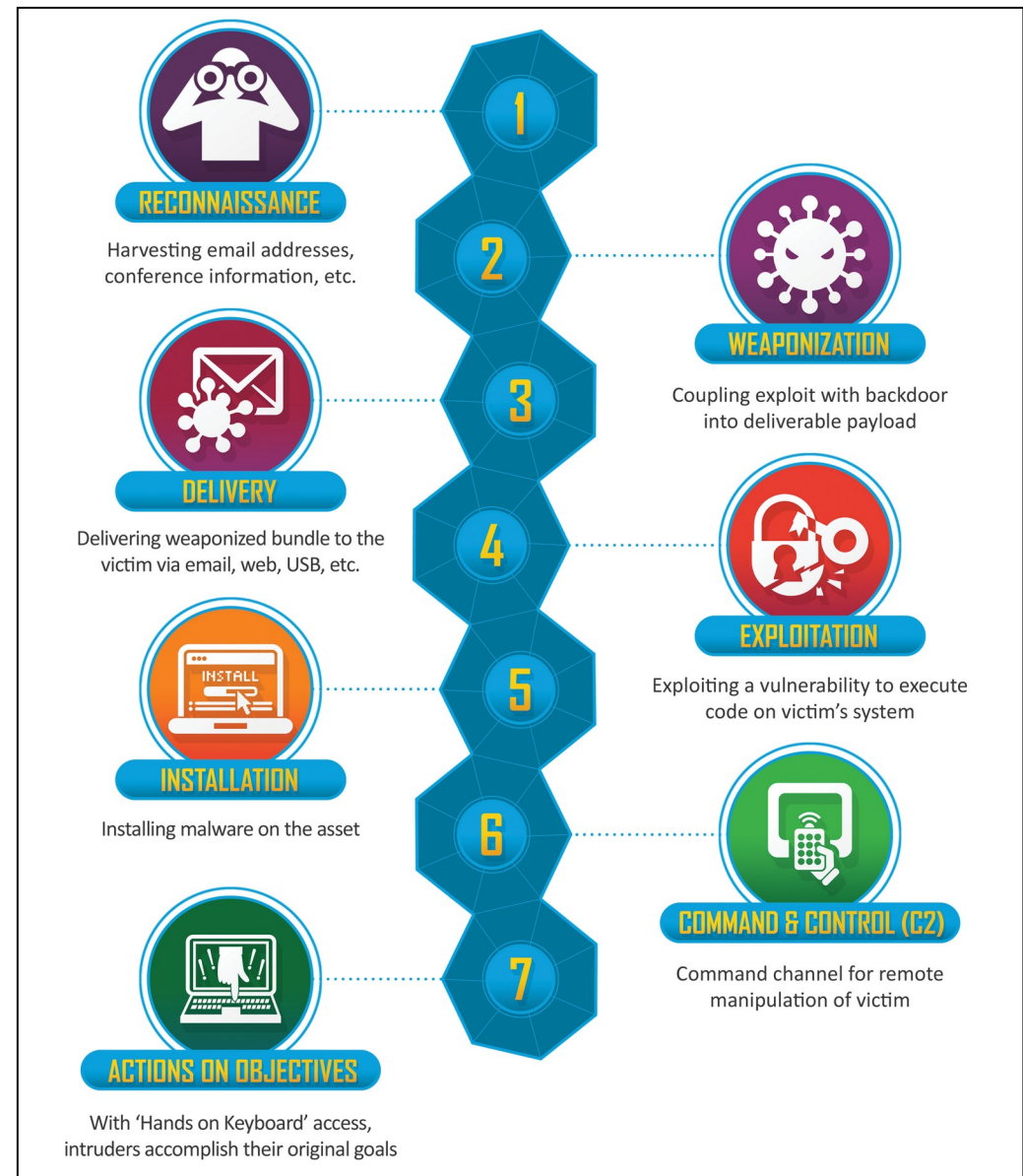
Timeline

- 2024-04-26 – vulnerability disclosed to Mozilla
- 2024-04-29 – PDF.js v4.2.67 released to NPM, fixing the issue
- 2024-05-14 – Firefox 126, Firefox ESR 115.11 and Thunderbird 115.11 released including the fixed version of PDF.js
- 2024-05-20 – publication of this blogpost

<https://codeanlabs.com/blog/research/cve-2024-4367-arbitrary-js-execution-in-pdf-js/>

Offensive security?

- Porsi nel ruolo degli attaccanti
 - verificare l'esistenza di vulnerabilità
 - stimare con precisione l'impatto degli attacchi
 - testare l'efficacia delle contromisure
- Modellare il processo di attacco: la **kill chain**
- Descrivere concretamente i passi: **MITRE ATT&CK**



Offensive security?

- Reconnaissance = primo anello della kill chain
<https://attack.mitre.org/tactics/TA0043/>

- In questa parte del corso

- enumerazione
- scansione
- brute forcing
- vulnerability assessment

limitatamente all'esposizione dei sistemi

Offensive security!

- Usare le stesse tecniche degli attaccanti è delicato
- MAI farlo su risorse non proprie senza permesso
- “permesso” è un termine da definire in modo ampio
 - semplici grattacapi da operazioni sospette
 - conseguenze legali
 - effetti imprevisti anche in buona fede
 - effetti sulle reti attraversate per raggiungere l’obiettivo lecito
- Scopo, efficacia ed efficienza dei test
 - velocità o precisione?
 - ricerca esaustiva di vulnerabilità o verifica della sensibilità dei sistemi di rilevazione?

VA → PT

- **VA trova solo vulnerabilità note**
- **Non procede oltre**
 - Sfruttando una vulnerabilità si potrebbe accedere a una vista più interna e approfondita del sistema, svelandone altre
- **Non considera la specificità del sistema**
 - Anche falsi positivi, es. servizi che dichiarano una versione vulnerabile ma sono stati corretti
- **PT: il tester (umano) avanza fin dove può, sfruttando le vulnerabilità per mezzo di exploit**
 - Più realistico
 - Report più dettagliato
 - RISCHIOSO

PT - punti di partenza

■ Valutazione del target

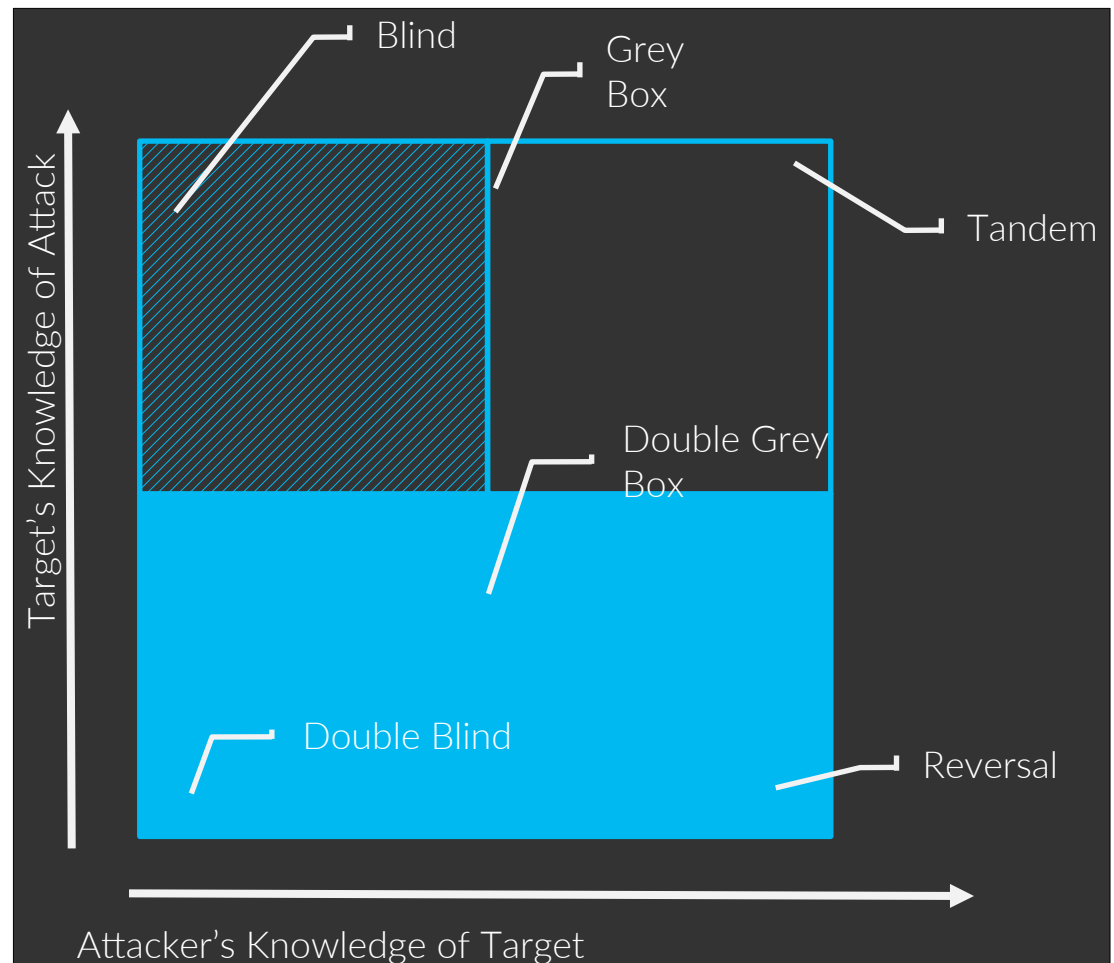
- vengono stabilite le regole di ingaggio
- mappatura, prioritizzazione, tracciamento dei confini

■ Postura e visibilità

- gli attacchi ciechi possono sembrare più realistici, ma fanno solo perdere tempo al tester esperto che è meglio spendere sui dettagli veramente nascosti

■ Protezione del bersaglio

- dove possibile, viene creata una replica per evitare di danneggiare il bersaglio, ma...
- alcuni sistemi sono semplicemente troppo complessi
- alcuni sistemi sono troppo critici per rischiare di perdere qualche dettaglio nella replica che potrebbe alterare il test



PT - metodologie



- **Seguire una metodologia consente di**
 - assicurarsi che il test sia coerente e ripetibile
 - eseguire una misurazione accurata della sicurezza (nessun pregiudizio o ipotesi o prove aneddotiche)
- **Esistono alcune metodologie generalmente accettate:**
 - Open Source Security Testing Methodology Manual (OSSTMM)
 - consente a qualsiasi tester di sicurezza di fornire idee per eseguire test di sicurezza più accurati, attuabili ed efficienti.
 - consente la libera diffusione delle informazioni e della proprietà intellettuale
- **Open Web Application Security Project (OWASP)**
 - specifico per applicazioni web
- **Payment Card Industry Data Security Standard (PCI DSS)**
 - settore finanziario; la sezione 11.3 riguarda il pentesting
- **Technical Guide to Information Security Testing and Assessment (NIST800-115)**
 - uno standard ufficiale del governo degli Stati Uniti
- **Information Systems Security Assessment Framework (ISSAF)**
 - completo ma non sviluppato attivamente

Preparazione

■ Reconnaissance

- raccolta di informazioni utili
- estensione del perimetro di test
- preparazione degli strumenti

■ Enumeration

- delimitazione del perimetro di test
- verifica puntuale delle risorse e delle loro proprietà

OSINT

■ Open Source INTelligence

- L'uso di qualsiasi fonte pubblicamente disponibile per ricavare informazioni su di uno specifico obiettivo
- Un campo di applicazione più ampio rispetto alla cybersecurity!

■ OSINT su altri (vedremo più avanti)

- componente della threat intelligence
- componente dell'incident response

■ OSINT su se stessi

- cosa possono scoprire gli avversari?
- come possono essere usate queste informazioni?

■ È legale?

- sostanzialmente sì
- attenzione alle aree grigie

<https://mediasonar.com/2020/03/11/10-tips-for-doing-osint-legally/>

OSINT – strumenti e fonti online

■ <https://osintframework.com/>

■ Ad esempio, per misurare l'esposizione dell'infrastruttura

- collocazione fisica
 - geolocation
 - rilevazione di indirizzi da documenti e pagine web
- collocazione in rete
 - domini DNS associati all'obiettivo
 - range di indirizzi IP
 - provider di connettività e autonomous systems
 - certificati X.509
- accesso ai servizi
 - porte raggiungibili
 - fingerprinting dei sistemi → anche notoriamente vulnerabili
 - username validi → anche con relative password

Google Dork

- Le Google Dorks o “Comandi di Google” costituiscono un metodo per affinare i risultati di ricerca.
- I comandi, anche detti operatori di ricerca, permettono di trovare, attraverso di esse, risultati precisi, corrispondenti al motivo per cui ti sei rivolto a Google.
- Per trovare risultati specifici infatti è sufficiente inserire, all'interno della query, qualche keyword particolare o simbolo in più per trovare risultati specifici.

Dorking as a Cyber Security Tool

- **Dorking può essere utile per un pentester nella fase di enumerazione (e non solo) di un determinato target.**
- **Inoltre, può aiutare a fornire informazioni approfondite quando si tratta di sicurezza e analisi della sicurezza di una architettura di un applicativo Web**
- **Quindi, in modo legittimo, google (e in generale tanti motori di ricerca che offrono questo tipo di funzionalità) offre uno dei migliori tool di OSINT a disposizione per “mappare” e/o “enumerare” tutte il possibile riguardo ad un preciso target.**

Qualche keyword

- **cache:** this dork will show you the cached version of any website, e.g. cache: securitytrails.com
- **allintext:** searches for specific text contained on any web page, e.g. allintext: hacking tools
- **allinurl:** it can be used to fetch results whose URL contains all the specified characters, e.g: allinurl client area
- **filetype:** used to search for any kind of file extensions, for example, if you want to search for jpg files you can use: filetype: jpg
- **inurl:** this is exactly the same as allinurl, but it is only useful for one single keyword, e.g. inurl: admin
- **intitle:** used to search for various keywords inside the title, for example, intitle:security tools will search for titles beginning with “security” but “tools” can be somewhere else in the page.
- **intext:** useful to locate pages that contain certain characters or strings inside their text, e.g. intext:"safe internet"
- **link:** will show the list of web pages that have links to the specified URL, e.g. link: microsoft.com
- **site:** will show you the full list of all indexed URLs for the specified domain and subdomain, e.g. site:securitytrails.com
- *****: wildcard used to search pages that contain “anything” before your word, e.g. how to * a website, will return “how to...” design/create/hack, etc... “a website”.

Esempio: Base

- La struttura generale di una query è la seguente:

"inurl:."domain"/"dorks" "

- Dove:
 - “inurl” = input URL
 - “domain” = dominio che si vuole enumerare
 - “dorks” = dork keyword che si vuole usare

Esempi:

- **Explore LOG Files For Login Credentials**
 - `allintext:password filetype:log after:2020`
- **Dork command using two google operators**
 - `allintext:username filetype:log`
- **Explore Live Cameras**
 - `inurl:top.htm inurl:currenttime`
- **Explore Open FTP Servers**
 - `intitle:"index of" inurl:ftp`
- **Explore last copy cache of a domain**
 - `cache:unibo.it`

Esempi concreti enumerazione target.

- Cerchiamo dei file pdf sul sito ulisse contenente la parola “password”
 - `site:ulisse.unibo.it filetype:PDF intext:password`
- Cerchiamo delle chiavi ssh indicizzate
 - `site:ulisse.unibo.it intitle:index.of id_rsa -id_rsa.pub`

.... Altre idee?

Contromisure

- Tutto ciò che google trova è perché è stato indicizzato.
- Conoscete il file robots.txt?

..... Usatelo! :)

User-agent: *

Disallow: /

Oppure

User-agent: *

Disallow: /cartellachenonvoleteindicizzare

Internet in poche slide, per l'enumeration

■ Approccio OSINT

■ Ogni host bersaglio ha un indirizzo IP

- I blocchi di IP sono assegnati dallo IANA ai RIR

<https://www.iana.org/numbers>

- I RIR li sub-allocano ai LIR, tenendo traccia di chi è l'effettivo responsabile di ogni blocco

■ Oltre agli indirizzi, sono molto utili i nomi DNS

- Ancora lo IANA coordina la concessione dei Top Level Domains

<https://www.iana.org/domains/root/db>

- Innumerevoli *registrar* si occupano della registrazione dei domini di secondo livello

Raccolta di informazioni – DNS

■ I record DNS possono svelare

- gli IP registrati dall'obiettivo
- l'esistenza e la collocazione di specifici server applicativi
- l'esistenza di sottoreti non direttamente raggiungibili
- alias per sistemi collocati al di fuori del perimetro dell'obiettivo
 - risorse in cloud
 - sistemi legati da relazioni di fiducia es. domini di una foresta Active Directory

■ Questo consente un notevole risparmio di tempo rispetto alla forza bruta

■ Aggravanti

- plateali: abilitazione di domain transfer
- sottili: permanenza di record rimossi nelle cache

■ Strumenti

- lookup di base: **host**, **dig**, **nslookup**
- strumenti di ricerca che includono guessing e forza bruta: **dnsenum**, **dnsmap**, **dnsrecon**, **fierce**, ...

<https://www.kali.org/tools/dnsrecon/>

<https://medium.com/@techmindxperts/what-is-dnsrecon-full-guide-with-examples-355aba308332>

Dns Enumeration

- Per DNS enumeration intendiamo il processo di individuazione di tutti i server DNS e dei record corrispondenti per un determinato target.
- L'elenco dei record DNS fornisce una panoramica del tipo dei record (record di database) registrati del Domain Name System (DNS). Il DNS implementa un database distribuito, gerarchico e ridondante per le informazioni associate ai nomi e agli indirizzi del dominio.

Dns Record Types

dns query	A	Address record , Returns a 32-bit IPv4 address, most commonly used to map hostnames to an IP address of the host, but it is also used for DNSBLs, storing subnet masks in RFC 1101, etc.
dns query	CNAME	Canonical name record , Alias of one name to another: the DNS lookup will continue by retrying the lookup with the new name.
dns query	AAAA	IPv6 address record , Returns a 128-bit IPv6 address, most commonly used to map hostnames to an IP address of the host.
dns query	MX	Mail exchange record , Maps a domain name to a list of message transfer agents for that domain
dns query	NS	Name server record , Delegates a DNS zone to use the given authoritative name servers
dns query	SOA	zone of authority record , Specifies authoritative information about a DNS zone, including the primary name server, the email of the domain administrator, the domain serial number, and several timers relating to refreshing the zone.
dns query	SPF	Sender Policy Framework , a simple email-validation system designed to detect email spoofing by providing a mechanism to allow receiving mail exchangers to check that incoming mail from a domain comes from a host authorized by that domain's administrators.
dns query	TXT	Text record , Originally for arbitrary human-readable text in a DNS record.
dns query	PTR	Pointer record , Pointer to a canonical name. Unlike a CNAME, DNS processing stops and just the name is returned. The most common use is for implementing reverse DNS lookups, but other uses include such things as DNS-SD.
dns query	SRV	Service locator , Generalized service location record, used for newer protocols instead of creating protocol-specific records such as MX.

nslookup

- Nslookup (acronimo di "Name Server Lookup") è un comando utile per ottenere informazioni dal server DNS. È uno strumento di amministrazione di rete per interrogare il Domain Name System (DNS) per ottenere la mappatura del nome del dominio o dell'indirizzo IP o qualsiasi altro record DNS specifico.

nslookup google.com

Server: 127.0.0.1

Address: 127.0.0.1#53

Non-authoritative answer:

Name: google.com

Address: 216.58.208.142

Name: google.com

Address: 2a00:1450:4002:805::200e

nslookup

- Nslookup (acronimo di "Name Server Lookup") è un comando utile per ottenere informazioni dal server DNS. È uno strumento di amministrazione di rete per interrogare il Domain Name System (DNS) per ottenere la mappatura del nome del dominio o dell'indirizzo IP o qualsiasi altro record DNS specifico.

nslookup -type=any google.com

Non-authoritative answer:

Name: google.com

Address: 216.58.208.142

Name: google.com

Address: 2a00:1450:4002:805::200e

.

.

Online tools

- <https://centralops.net/> Domain Dossier
- <https://dnsdumpster.com/> Potente suite di Recon
- <https://whois.domaintools.com/> Whois generico.
- <https://reverseip.domaintools.com/> Reverse Lookup
ovvero, partendo da un IP address vengono mostrati
tutti i domini hostati nell'IP specificato, incluso
subdomain.

Altri tool

■ Dnsrecon

```
# apt install dnsrecon
```

```
$ dnsrecon -d DOMAIN
```

■ Dnsmap

```
# apt install dnsmap
```

```
$ dnsmap DOMAIN
```

Altri tool: Shodan.io

shodan.io/host/137.204.24.147

Apps Security Roba Varia BugBounty Deep MIO CV Studiare Finanza Chimica Didattica Hack Case

Shodan Maps Images Monitor Developer More...

SHODAN Explore Pricing Search... Login

137.204.24.147 Regular View Raw Data History

// LAST SEEN: 2022-02-18

General Information

Country	Italy
City	Bologna
Organization	UNI-Bologna
ISP	Consortium GARR
ASN	AS137

Open Ports

80

// 80 / TCP -1427803479 | 2022-02-18T12:02:07.058060

nginx

HTTP/1.1 301 Moved Permanently
Server: nginx
Date: Fri, 18 Feb 2022 12:02:06 GMT
Content-Type: text/html
Content-Length: 178
Connection: keep-alive

Subdomain Enumeration

- È una delle parti più cruciali della fase di enumerazione. L'enumerazione dei sottodomini è un processo di ricerca dei sottodomini di uno o più domini root. Secondo RFC 1034, "un dominio è un sottodominio di un altro dominio se è contenuto all'interno di quel dominio".



The diagram illustrates the hierarchical structure of the domain `app.admin.blog.example.com` with labels for each part:

- `app`: third-level subdomain
- `admin`: second-level subdomain
- `blog`: first-level subdomain
- `example`: root domain
- `com`: top-level domain

Subdomain Enumeration

- L'enumerazione dei sottodomini permette di ampliare enormemente la superficie d'attacco durante una campagna di offensive security.
- L'output tra i più interessanti da trovare in questa fase sono domini nascosti, bloccati o duplicati “minori”.
- Dietro a questo sottodomini possono infatti nascondersi applicativi o servizi “dimenticati”, non aggiornati o non difesi correttamente.
- Una buona strategia di enumerazione sottodomini è quindi fondamentale.

Subdomain Enumeration, precisazioni.

- Un Fully Qualified Domain Name (FQDN) rappresenta un dominio completo per uno specifico host.
- Un FQDN è ad esempio:
 - miopc.ulisse.com ----> Fully Qualified Domain Name
- miopc --> è l'host di ulisse.com (subdomain)
- Però;
 - https://ulisse.com
 - http://myaltropc.ulisse.com
 - https://internal.accounts.ulisse.com
 - https://internal.accounts.pannelloadmin.ulisse.com
- I domini sopra NON sono subdomain di ulisse.com. Sono link a web application (http) hostati sulle porte 80 & 443 dei loro rispettivi host.

Subdomain Enumeration, precisazioni.

- Prendiamo ad esempio `corsosec.ulisse.com`. Dietro questo subdomain potrebbe non esserci nessun applicativo web dietro le classiche porte 80 e 443.
- Questo non significa però che non sia un subdomain valido!
- L'applicativo web infatti potrebbe infatti essere esposto sulla porta 8080, o su un'altra porta.
- Oppure dietro a quel dominio potrebbe essere hostato un altro tipo di servizio non necessariamente di tipo web.
- È quindi buona pratica mappare tutti i subdomain disponibili per un dominio, e risolverli provando a capirne il servizio che c'è dietro.

Subdomain Enumeration.

- Esistono fondamentalmente due strategie:
 - PASSIVA
 - ATTIVA
- Con la strategia Passiva facciamo delle query a dei dataset di DNS noti, che forniscono questi dati, per ottenere tutte le informazioni che cerchiamo, ad esempio
 - Security Trails <https://securitytrails.com/>
 - Shodan <https://www.shodan.io/>
 - Censys <https://censys.io/>
 - Binaryedge <https://www.binaryedge.io/>
 - VirusTotal <https://www.virustotal.com/gui/>
 - ecc

Subdomain Enumeration.

- Esistono molti tool che “wrappano” in automatico tutte le richieste a questi portali noti in un unico output.
- Un esempio molto noto è amass, sviluppato dalla OWASP foundation.
 - <https://github.com/OWASP/Amass>

Altri tool noti

- <https://github.com/projectdiscovery/subfinder>
- <https://github.com/tomnomnom/assetfinder>
- <https://github.com/Findomain/Findomain>
-

Subdomain Enumeration. CT Abuse

- **Certificate Transparency:** Per poter criptare il traffico per gli utenti, un sito deve innanzitutto richiedere un certificato a un'autorità di certificazione (CA) attendibile.
- Il certificato viene poi presentato al browser per l'autenticazione del sito a cui l'utente desidera accedere. Negli ultimi anni, le CA e i certificati emessi si sono rivelati vulnerabili alla compromissione e alla manipolazione, a causa di falle strutturali nel sistema dei certificati HTTPS.
- Il progetto Certificate Transparency di Google è stato ideato per proteggere il processo di emissione dei certificati offrendo un framework aperto per il monitoraggio e il controllo dei certificati HTTPS.

Subdomain Enumeration. CT Abuse

- Un log di Certificate Transparency è un server che implementa RFC 6962 e consente a qualsiasi parte interessata di inviare certificati che sono stati emessi da un'autorità di certificazione pubblicamente attendibile. Una volta che un log accetta un certificato, le proprietà crittografiche del log assicurano che la voce non potrà mai essere rimossa o modificata.
- Ciò significa che tutti i certificati emessi dalla CA verrebbero aggiunti a un elenco pubblico comune. Avere un registro trasparente di tutti i certificati emessi è un'ottima soluzione per risolvere il problema dell'emissione fraudolenta di certificati, poiché i legittimi proprietari di domini hanno la possibilità di individuare i certificati emessi senza il loro consenso.

Subdomain Enumeration. CT Abuse

- Poiché ogni volta che un'organizzazione ottiene un certificato SSL viene registrata in questi registri CT, è possibile abusarne facilmente. Poiché chiunque può interrogarli, possono essere utilizzati per enumerare i sottodomini di un dominio principale che hanno un certificato TLS associato.
- Possiamo trovare tutti i certificati SSL appartenenti a un dominio inviando una richiesta GET a **<https://crt.sh/?q=%25.dell.com>**

crt.sh Identity Search  Group by Issuer									
Criteria Type: Identity Match: ILIKE Search: 'dell.com'									
Certificates	crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name		
	2398054168	2020-01-29	2015-07-15	2017-06-12	RUBIN.MARK.ISADORE.1043574880	mark_rubin@federal.dell.com	C=US, O=U.S. Government, OU=DoD, OU=PKI, CN=DOD EMAIL CA-32		
	2398051248	2020-01-29	2012-08-09	2015-08-08	RUBIN.MARK.ISADORE.1043574880	mark_rubin@federal.dell.com	C=US, O=U.S. Government, OU=DoD, OU=PKI, CN=DOD EMAIL CA-30		
	2398012835	2020-01-29	2013-10-23	2014-10-23	Hurley.Brendan.FORC1000038623.Encrypt	Brendan_Hurley@federal.dell.com	C=US, O=U.S. Government, OU=ECA, OU=Certification Authorities, CN=ORC ECA HW.4		
	2398012604	2020-01-29	2013-02-14	2014-02-14	Kamanda.Ernestine.O.ORG1000032582.Encrypt	Ernestine_Kamanda@federal.dell.com	C=US, O=U.S. Government, OU=ECA, OU=Certification Authorities, CN=ORC ECA HW.4		
	2382777596	2020-01-27	2015-04-08	2017-04-08	nexusapp.us.dell.com	nexusapp.us.dell.com	C=NL, L=Amsterdam, O=Verizon Enterprise Solutions, OU=Verizon Public SureServer CA G14-SHA2		
	2382769749	2020-01-27	2015-05-11	2017-05-11	ebi.us.dell.com	ebi.us.dell.com	C=NL, L=Amsterdam, O=Verizon Enterprise Solutions, OU=Verizon Public SureServer CA G14-SHA2		
	2382733309	2020-01-27	2015-07-17	2017-07-17	tpepwucsba01.tpe.apac.dell.com	tpepwucsba01.tpe.apac.dell.com	C=NL, L=Amsterdam, O=Verizon Enterprise Solutions, OU=Verizon Public SureServer CA G14-SHA2		
	2382711925	2020-01-27	2016-06-08	2017-06-08	indiacp.portal.dell.com	indiacp.portal.dell.com	C=US, O="Entrust, Inc.", OU=See www.entrust.net/legal-terms, OU="(c) 2012 Entrust, Inc. - for authorized use only", CN=Entrust Certification Authority - L1K		
	2382711981	2020-01-27	2016-11-08	2017-10-31	dellidm.dell.com	dellidm.dell.com	C=US, O="Entrust, Inc.", OU=See www.entrust.net/legal-terms, OU="(c) 2012 Entrust, Inc. - for authorized use only", CN=Entrust Certification Authority - L1K		
	2382711642	2020-01-27	2016-11-03	2017-11-03	pvwa.us.dell.com	auspwwweb01.aus.amer.dell.com auspwwweb02.aus.amer.dell.com auspwwweb02.us.dell.com pvwa.aus.amer.dell.com pvwa.ins.dell.com pvwa.us.dell.com	C=US, O="Entrust, Inc.", OU=See www.entrust.net/legal-terms, OU="(c) 2012 Entrust, Inc. - for authorized use only", CN=Entrust Certification Authority - L1K		
	2382705131	2020-01-27	2015-01-21	2017-01-21	lync-intowa-blr.dell.com	blrpwlyncowa101.blr.amer.dell.com blrpwlyncowa102.blr.amer.dell.com lync-extowa-blr.dell.com lync-intowa-blr.dell.com	C=NL, L=Amsterdam, O=Verizon Enterprise Solutions, OU=Verizon Public SureServer CA G14-SHA2		
	2382688313	2020-01-27	2014-11-06	2016-11-06	penpwlyncfe107.pen.apac.dell.com	admin.dell.com dialin.dell.com Lyncdiscover.dell.com LyncdiscoverInternal.dell.com meet.dell.com penpwlyncfe107.pen.apac.dell.com webext-penpwlyncfe107.dell.com	C=NL, L=Amsterdam, O=Verizon Enterprise Solutions, OU=Verizon Public SureServer CA G14-SHA2		

Subdomain Enumeration.

- Non c'è una vera e propria difesa da questo tipo di enumerazione, dal momento che i subdomain sono in ogni caso esposti.
- È bene però sapere la propria superficie d'attacco esposta, e a cosa ogni subdomain è associato.

Altre tecniche includono:

- DNS bruteforcing (non fatelo! :))
- Permutation/Alternations
- VHOST probing
- Recursive Enumeration

Esercitazioni e Materiale Approfondimento

Google Dork

- <https://www.oakton.edu/user/2/rjtaylor/cis101/Google%20Hacking%20101.pdf>
- <https://www.exploit-db.com/google-hacking-database>
- https://www.researchgate.net/publication/335383170_Google_Dorks_-_Advanced_Searching_Technique
- <http://pdf.textfiles.com/security/googlehackers.pdf> (ottimo!)

DNS Enum

- <https://pentestwiki.org/enumeration-cheat-sheet/>
- <https://www.exploit-db.com/docs/english/13687-how-to-dns-enumeration.pdf>

Subdomain Enum

- <https://pentester.land/cheatsheets/2018/11/14/subdomains-enumeration-cheatsheet.html>
- <https://sidxparab.gitbook.io/subdomain-enumeration-guide/>

Nmap

- <https://nmap.org/book/cover/nns-cover.pdf>

Raccolta di informazioni – IP blocks

- La conoscenza dei dettagli organizzativi o di pochi indirizzi IP validi può permettere di espandere la conoscenza
 - agli interi blocchi allocati all'obiettivo
 - ad altri blocchi non evidentemente collegati
- Esempio
 - da www.unibo.it riuscite a risalire a tutte le reti degli enti di ricerca e delle università italiane?
 - hint: strumenti di ricerca [RIPE](#)

Enumerazione – host

- Una volta individuati i blocchi di indirizzi da analizzare – o se ci si trova già sulla rete bersaglio, di cui si conoscono i parametri – si procede con l'individuare gli host effettivamente attivi (live host)
- Banale **ping**
 - 1 indirizzo per volta
 - da fuori: bloccato da router e firewall?
 - anche da dentro: ignorato da host?
 - scansione mirata ai servizi (in seguito)
- Scansioni massive
 - **masscan**
- Su rete locale più strumenti
 - host potrebbero ignorare richieste IP
 - sniffing passivo (**wireshark**, **tshark**, **tcpdump**, ...)
 - **arping**

Servizi e porte

- Su ogni host i servizi raggiungibili stanno in ascolto (*listen*) su porte TCP oppure UDP
- Well-known ports
 - indovinate chi le assegna...
<https://www.iana.org/assignments/service-names-port-numbers/service-names-port-numbers.xhtml>
 - file `/etc/services`

Enumerazione – servizi

- Determinati gli host raggiungibili, si cercano le porte aperte
 - le due fasi possono collassare in una, se si sospetta che gli host interessanti ignorino i ping → test di vitalità fatto direttamente sondando le porte
- Il tool più diffuso: **nmap**
 - scansione contemporanea di range di indirizzi e porte
 - set predefinito di porte “più popolari”
<https://nmap.org/book/port-scanning.html>
 - diverse tipologie di scansione
 - fingerprinting del sistema operativo e delle versioni dei servizi
- Alcuni vantaggi di **unicornscan** su **nmap**
 - fingerprinting più affidabile
 - relativamente più veloce
 - può salvare le risposte per analisi con altri strumenti

Evasione

■ Scopi della fase di OSINT ed enumerazione

- testare l'efficacia delle difese (IDS)
- preparare il terreno per condurre un test della massima accuratezza evitando di incorrere in impedimenti (IPS)

→ **Reconnaissance in modalità anonima**

- ToR o simili
- creazione di account usa e getta sui siti
- utilizzo di VM diverse e periodicamente sostituite

→ **Enumerazione in modalità “stealth”**

- temporizzazione configurabile
- randomizzazione di indirizzi e porte
- non utilizzare lo stack TCP/IP dell'host di origine (unicornscan) per evitare reverse fingerprinting

→ **Enumerazione adattativa rispetto a FW, IDS e IPS**

<https://nmap.org/book/firewalls.html>

Tentativi di accesso ai servizi

- **Analisi dei protocolli applicativi più comuni**
 - SMB, SMTP, SNMP
 - può portare ad accesso a dati o a raccolta di ulteriori informazioni per le fasi successive
- **Brute forcing applicativo (fuzzing)**
 - invio di payload randomizzati per tentare di sollecitare risposte impreviste (Es. **bed**, **doona**, vari tool per SIP, ...)
- **Framework per lo sviluppo e l'esecuzione di exploit**

La postura interna

- **Reconnaissance ed enumeration sono svolte da una postura esterna al perimetro di difesa dell'obiettivo**
 - più fedele alla postura dell'attaccante
 - ma se non catturano un metodo di intrusione?
- **Possibilità: auto-attaccarsi dalla posizione più vantaggiosa, all'interno**
 - NIDS e FW tipicamente scavalcanti
 - sistemi raggiunti senza ostacoli
 - miglior test per HIDS
 - maggior efficienza
- **Verifiche tipiche (oltre a quanto visto)**
 - esposizione servizi in rete
- **(prossima puntata)**
 - controllo dell'accesso (utenti, permessi)
 - iniezione di software e occultamento di processi

Reti

- **Wireless: un modo eccellente di guadagnare una postura interna, se ci si trova fisicamente a portata di segnale**
 - accesso alle comunicazioni
 - possibilità di attacco dei sistemi raggiungibili
- **WiFi: <http://www.aircrack-ng.org/>**
 - cattura di pacchetti per analisi successiva
 - attacchi di tipo replay e deauthentication
 - creazione di finti access point
 - cracking della chiave per WEP, WPA1-PSK, WPA2-PSK
- **Non solo WiFi**
 - bluetooth, NFC, SDR in generale
- **Post-accesso wireless o fisico**
 - toolkit per l'esecuzione di MITM

Strumenti di ricerca completi

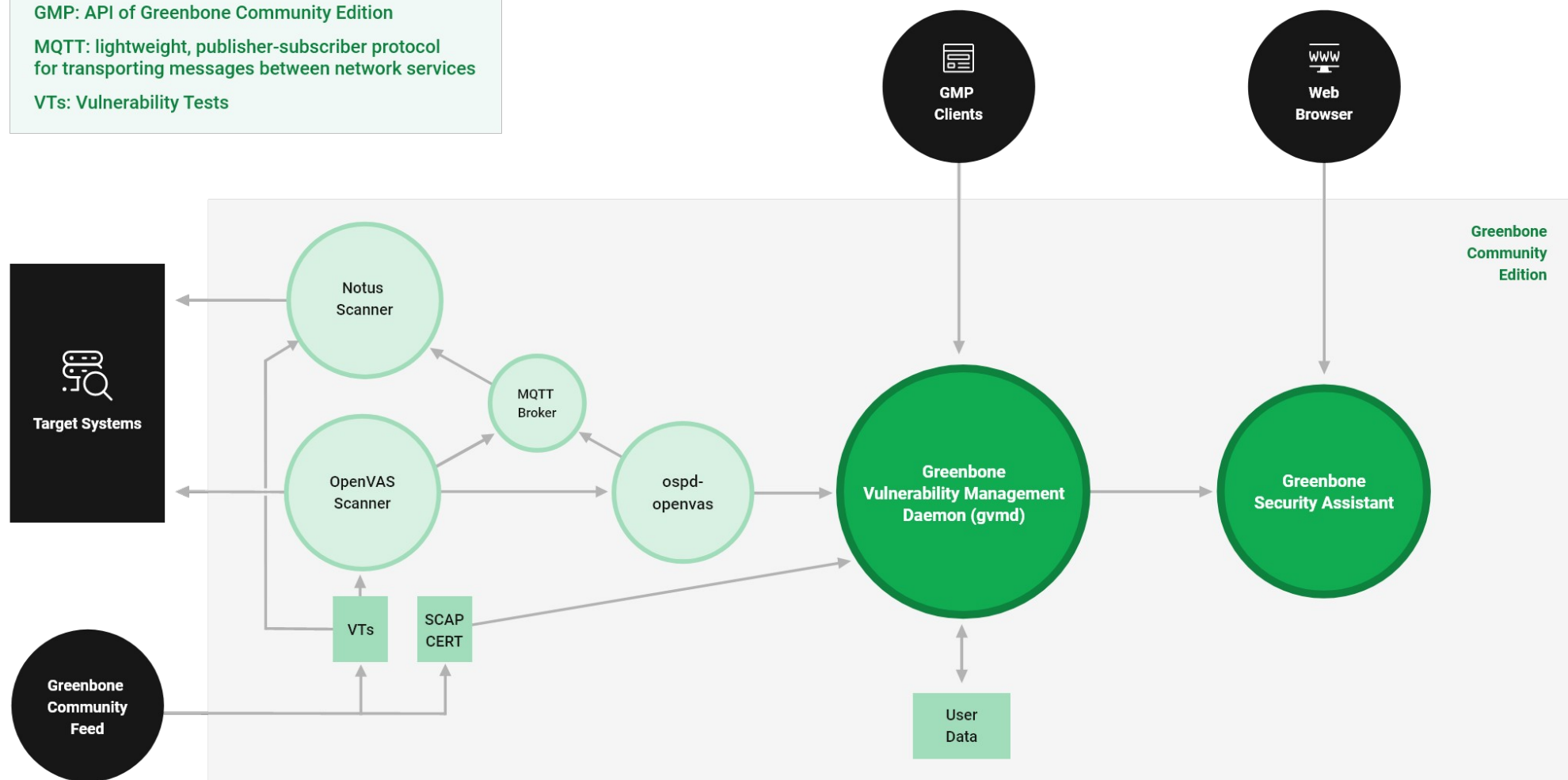
- **Esistono scanner di vulnerabilità completi**
 - configurabili per eseguire la scansione di una combinazione arbitraria di host e porte
 - possono testare l'esistenza di vulnerabilità a livello di rete, sistema operativo e applicazione tramite plug-in caricabili
 - possono collegare ogni vulnerabilità alla documentazione pertinente (ad esempio CVE)
- **Il più noto è Nessus, un prodotto commerciale di Tenable,**
 - www.nessus.org
- **OpenVAS è l'open-source equivalente ([breve storia](#))**
 - fork causato dal passaggio di Nessus a licenza proprietaria (2005)
 - dal 2008 attivamente sviluppato da Greenbone, ora evoluto in Greenbone Community Edition ([GCE](#)) e parte della loro linea Enterprise
 - www.openvas.org

Architettura di GCE

GMP: API of Greenbone Community Edition

MQTT: lightweight, publisher-subscriber protocol for transporting messages between network services

VTs: Vulnerability Tests



Feed, il valore fondamentale

■ Si appoggia su di un vulnerability database

- Network Vulnerability Tests = descrizione della vulnerabilità + piattaforme colpite + processo di verifica
- aggiornato ogni giorno!

<https://www.greenbone.net/en/feed-comparison/>

